

Manual Testing Report (VAPT)

Project Name: global	Department: Software	Date: 21/09/2026
URL: http://global.com		
Security Analyst: BISAG-N Administrator, Nensi	Concern Project Manager: Shri	
Project Manager: ABCD, WXYZ	Concern Additional Director: Shri Krunal Patel	
Additional Director cum CISO: Shri Krunal Patel		

S.No	Vulnerability Name	Description	Step to reproduce	Remediation	Severity	Reference	OWASP Category – CWE number	CWE Reference
1	SQL Injection (Blind / Error-Based)	SQL injection is a web security vulnerability that allows an attacker to interfere with the queries that an application makes to its database, allowing unauthorized data retrieval or modification.	1. Navigate to search or login parameter. 2. Inject payload: ' OR '1'='1. 3. Observe database error or authentication bypass.	1. Use parameterized queries / prepared statements for all SQL execution. 2. Use Object Relational Mapping (ORM) safely. 3. Enforce principle of least privilege on database accounts.	Critical	OWASP / CWE	A03 - (CWE-89)	CWE-89
2	Insecure Direct Object Reference (IDOR)	The application uses user-supplied input to access objects directly without proper access control checks, allowing unauthorized users to view or modify records belonging to other users.	1. Login as User A and view profile with ID 101. 2. Change request parameter ID to 102. 3. Observe unauthorized access to User B's sensitive data.	1. Implement robust server-side authorization checks on all resource endpoints. 2. Use non-sequential random identifiers (UUIDs) where applicable.	High	OWASP / CWE	A01 - (CWE-639)	CWE-639
3	Clickjacking / Missing X-Frame-Options	The web page does not restrict framing via X-Frame-Options or Content-Security-Policy frame-ancestors, enabling attackers to render the page inside a transparent iframe and trick users into clicking buttons.	1. Create an HTML file with <iframe src='TARGET_URL'></iframe>. 2. Open in browser and verify the application renders successfully within the iframe.	1. Configure 'X-Frame-Options: DENY' or 'SAMEORIGIN'. 2. Implement Content Security Policy with 'frame-ancestors 'self'".	Medium	OWASP / CWE	A05 - (CWE-1021)	CWE-1021
4	CORS Misconfiguration (Arbitrary Origin Allowed)	The application's Cross-Origin Resource Sharing (CORS) policy reflects arbitrary origins or allows wildcard with credentials, enabling malicious third-party websites to extract sensitive user data.	1. Send request with header 'Origin: https://attacker.com'. 2. Check response for 'Access-Control-Allow-Origin: https://attacker.com' and 'Access-Control-Allow-Credentials: true'.	1. Whitelist only trusted domains for CORS. 2. Do not reflect arbitrary Origin headers when Access-Control-Allow-Credentials is true.	Medium	OWASP / CWE	A07 - (CWE-942)	CWE-942
5	Deprecated X-XSS-Protection Header	The application uses the deprecated X-XSS-Protection HTTP response header. Modern browsers have removed support for this header because it can introduce security vulnerabilities in certain contexts.	1. Visit target URL: http://localhost:5173/report-generator 2. Intercept the request. 3. Send to Repeater. 4. Inspect the response headers.	1. Remove deprecated X-XSS-Protection header. 2. Implement Content Security Policy (CSP). 3. Implement input validation and output encoding. 4. Configure secure cookie settings.	Low	OWASP / CWE	A05 - (CWE-1021)	CWE-1021

Form No.: BISAG/SD/FR-207 R01

Remarks:

Functional Testing Report form was not provided at the time of the project submission to the Security Testing Team.
As per the remarks provided by the development team in the request form, --- are out of scope.
Testing was conducted using only the following provided credentials: